International Cybersecurity and Digital Forensics Academy (ICDFA)

Course Code: GRC103 – Risk Assessment and Management Techniques

Practical Laboratory 3A

Phishing Risk Analysis Report

Phishing Simulation Metrics and Quantitative Risk Analysis

Scenario: GlobalTech Inc., lead GRC analyst report

Student Name: Mercy Ajayi

Registration Number: C11/26/CGRCE/17219

Date of Submission: November 1, 2026

TABLE OF CONTENTS

1. Campaign metrics..... 1
2. Annual loss model and risk assessment matrix..... 2
3. Statistical analysis..... 4
4. Control recommendation table..... 5
5. Executive briefing..... 6
    Key findings..... 6
    Business implications..... 6
    Recommended actions..... 6
    Limitations..... 7
6. Corrected figures and assumptions..... 8
    A. Errors in the lab brief, corrected under the lab's own method:..... 8
    B. Method changes, where an unjustified assumption was replaced by an explicit one:.. 9

This report accompanies the calculation workbook (Lab3A_Calculation_Workbook.xlsx), where every figure below is a visible formula. Three labels are used throughout. Supplied means the figure came from the lab brief or the study guide. Scenario assumption means a value that has not been verified, such as the breach cost, the breach probability, how well a control works, or how often attacks happen. Corrected means the lab brief printed a different figure and it has been replaced. Every correction is listed, with its reason, in section 6.

1. Campaign metrics

All rates divide by emails sent. Conversion rates divide by the stage before. Click-through rate (clicks ÷ sent) and credential submission rate (credentials ÷ sent) are different measures, and the lab brief mixes them up in one place (section 6).

Campaign	Open rate	Click-through	Credential submission	Data entry	Open-to-click	Post-click submission
A: HR Bonus Notification (100 staff)	82%	47%	18%	5%	57.3%	38.3%
B: IT Password Reset (250 staff)	80%	60%	30%	10%	75%	50%
C: CEO Urgent Document (80 executives and assistants)	90%	75%	15%	10%	83.3%	20%
All three combined (430 emails)	82.3%	59.8%	24.4%	8.8%	72.6%	40.9%

The study guide gives 2024 reference ranges of 30-40% for opens, 10-15% for clicks and 3-5% for credential submission. These are course reference points, not verified benchmarks. GlobalTech's results sit well above all three.

2. Annual loss model and risk assessment matrix

The lab brief multiplies 600 compromised accounts by 25% to get 150 independent breaches a year, each costing $4.35M. That gives $652.5M, but it has two problems. Accounts compromised by the same phishing wave share one cause, so treating each as its own breach has no stated justification. And the simulation covers one quarter, so calling the result annual has no basis either.

This report uses an explicit annual occurrence assumption instead:

- **Waves per year (scenario assumption):** 4, one credential-theft wave per quarter, matching the quarterly simulation cadence.
- **Chance a wave leads to a major breach:** 25%, supplied by the lab and read as per wave rather than per account. It is a scenario assumption, not a verified figure.

- **Breach cost (SLE):** $4,350,000, supplied by the lab as an industry average. It is a scenario assumption, not a verified benchmark.

- **Campaign differences:** breach likelihood is assumed to scale with each campaign's credential rate, relative to Campaign B (the highest, at 30%).

So Campaign B has 4 × 25% = 1.0 breach a year, and annual loss (ALE) = SLE × ARO = $4,350,000 \times 1.0$. $Campaigns A and C scale to 0.6 and 0.5 breaches a year. Rating thresholds($4M for CRITICAL, $2M for HIGH) are my own assumptions.

Campaign	Credential rate	Compromised accounts (of 2,000)	Breaches per year	Annual loss (base case)	Rating	Priority	Lab-literal ceiling
B: IT Password Reset	30%	600	1.0	$4,350,000	CRITICAL	1	$652,500,000
A: HR Bonus Notification	18%	360	0.6	$2,610,000	HIGH	2	$391,500,000 (corrected)
C: CEO Urgent Document	15%	300	0.5	$2,175,000	HIGH	3	$326,250,000 (corrected)

The last column shows the lab's own method, with its arithmetic fixed, so the gap between the two approaches is visible. It is an upper bound for comparison and is not used for the ratings.
Campaign B, priority 1, immediate MFA. It has the highest credential rate, and half of the people who clicked went on to submit credentials. It also has the largest sample, so its estimate is the most reliable. Password-reset lures imitate routine IT mail, which is why they work.
Campaign A, priority 2, enhanced training. One in five staff gave up credentials to a bonus lure. The estimate is less certain because only 100 people were tested.
Campaign C, priority 3 by annual loss, executive training. Three in four executives clicked, and these accounts carry the most privileged access, so I rate it HIGH even though its loss figure is lowest. Only 80 people were tested, and executives are not typical staff, so the loss figure

assumes their behaviour generalises. I recommend executive-specific training and phishing-resistant sign-in for privileged accounts

3. Statistical analysis

Formula (study guide): $p \pm 1.96 \times \sqrt{[p(1-p) \div n]}$.

Campaign	n	p	Margin of error	95% interval	Base-case annual loss range
A	100	18.0%	±7.5 points	10.5% to 25.5%	$1.52M to $3.70M
B	250	30.0%	±5.7 points	24.3% to 35.7%	$3.53M to $5.17M
C	80	15.0%	±7.8 points	7.2% to 22.8%	$1.04M to $3.31M

Campaign A worked through: 0.18 × 0.82 = 0.1476. Divide by 100 to get 0.001476, and the square root is 0.0384. Multiply by 1.96 to get 0.0753. So the interval is 0.18 ± 0.0753, or 10.5% to 25.5%.

What the intervals tell us. Campaign B's interval does not overlap with Campaign C's, so B really is more successful than C. B and A overlap slightly, and A and C overlap heavily. The data cannot show that A and C differ from each other, even though their sample rates are 18% and 15%. Even at the bottom of every interval, the credential rates are above the study guide's 3-5% range.

Sampling limitations.

The target groups have different sizes (100, 250 and 80), so the margins of error differ. Smaller groups give wider intervals.

- Campaign C targeted executives and assistants. That group does not represent the other 1,920 employees, so projecting its rate across the company is a stretch.
- The brief does not say the groups were chosen at random. If they were hand-picked, the intervals understate the true uncertainty.
- Each campaign used a different lure, so the effect of the lure cannot be separated from the effect of the audience.
- The data covers one quarter. Click behaviour shifts with training, workload and season.
- The normal-approximation formula is acceptable here, because each group has at least 5 successes and 5 failures (the smallest is 12 successes in Campaign C).
- The annual-loss ranges show sampling uncertainty only. They do not cover uncertainty in the wave frequency, breach probability or breach cost, which are scenario assumptions.

4. Control recommendation table

Baseline is Campaign B's base-case annual loss of $4,350,000. Costs are supplied by the lab. The effectiveness values (99.9%, 60%, 20%) are scenario assumptions, not verified benchmarks. The 20% for email filtering is implied by a $130.5M benefit the lab printed against its $652.5M figure, and the study guide's 70-90% describes emails blocked, not loss reduction.

Control	Cost	Assumed effectiveness	Annual benefit	Net benefit	ROI	Break-even effectiveness	Break-even ALE	Break-even breaches per year
MFA	$90,000	99.9%	$4,345,650	$4,255,650	4,729%	2.07%	$90,090	0.021
Security awareness training	$100,000	60%	$2,610,000	$2,510,000	2,510%	2.30%	$166,667	0.038
Email filtering	$50,000	20%	$870,000	$820,000	1,640% (corrected method)	1.15%	$250,000	0.057

Break-even (optional calculation). Break-even effectiveness is cost ÷ ALE, the smallest reduction that repays the control. For MFA that is $90,000 ÷ $4,350,000 = 2.07%, so MFA pays for itself even if it works at a fraction of the assumed 99.9%. Break-even breaches per year is cost ÷ (SLE × effectiveness). For MFA it is 0.021, roughly one avoided breach every 48 years. Sensitivity to breach frequency. The case holds across low, base and high scenarios. The last row is the lab's 150-breach figure, shown only as a ceiling.

Scenario	Waves per year	Breaches per year	Annual loss	MFA ROI	Training ROI	Email filtering ROI	Full programme ROI
Low (assumption)	2	0.5	$2,175,000	2,314%	1,205%	770%	299%
Base case (assumption)	4	1.0	$4,350,000	4,729%	2,510%	1,640%	699%
High (assumption)	12	3.0	$13,050,000	14,386%	7,730%	5,120%	2,297%

Control benefits overlap, so they should not be added together. The full programme in section 5 uses the lab's assumed 90% combined reduction instead.

5. Executive briefing

To: Board of Directors, CISO, CFO

From: Mercy Ajayi, GRC Risk Analysis

Date: 1 November 2026

Subject: Phishing risk assessment and recommended security investment

Key findings

- Across 430 simulated emails, 24.4% of recipients submitted credentials. The study guide's reference range is 3-5%.

- The IT password-reset lure was the most effective. 30% of recipients submitted credentials, and half of those who clicked did so.

- Executives clicked most often (75%) but mostly stopped before submitting (20% of clickers). Their accounts are still the most valuable targets.

- Projected across 2,000 employees, the password-reset result implies about 600 compromised accounts. Assuming four credential-theft waves a year and a 25% chance each leads to a major breach, expected annual loss is about $4.35M (scenario assumptions, including the lab's $4.35M breach cost).

Business implications

The lab's own method gives $652.5M a year, but that figure treats every compromised account as a separate breach and is not used here. On the more defensible basis the exposure is still material: about one major breach a year, costing about $4.35M. The controls cost a small fraction of that. MFA costs $90,000 and repays itself if it prevents one breach every 48 years. The main finding is not the exact dollar figure but that staff are giving away credentials at several times the reference rate, and stolen credentials are usually the first step in a breach.

Recommended actions

Immediate (first quarter):

- Enforce MFA across the organisation: $90,000.
- Run mandatory awareness training with refreshers: $100,000.
- Launch a recurring targeted phishing simulation programme: $25,000.

Strategic (next financial year):

- Deploy an advanced email security gateway: $50,000.
- Establish continuous security monitoring: $150,000.

- Implement security behaviour analytics: $75,000.

Total investment: $490,000. Under the lab's assumed 90% combined reduction, the programme cuts annual loss by $3,915,000 and leaves $435,000. Net annual benefit is $3,425,000 (ROI 699%). Even in the low scenario of one wave every six months, the programme returns 299%. It breaks even at about 0.125 breaches a year, or one avoided breach every eight years.

Limitations

- The annual figures rest on scenario assumptions that have not been verified: four waves a year, a 25% breach chance per wave, a $4.35M breach cost, and the control effectiveness percentages.

- Breach likelihood is assumed to scale with credential rate. That is a modelling choice, not an observed relationship.

- Samples are small and differ in size and audience. Campaign C is an executive group, so its rate should not be applied to the whole company.

- No control is 100% effective, and MFA at 99.9% is the most optimistic of the assumptions.

- Ongoing costs (training refreshers, licence renewals) and indirect costs (reputation, customer loss) are not included.
- The ROI percentages are best used to rank controls, not to quote as expected returns.

6. Corrected figures and assumptions

A. Errors in the lab brief, corrected under the lab's own method:

Item	Lab figure	Corrected figure	Reason
Campaign A exposure	$156,600,000	$391,500,000	360 × 25% × $4,350,000
Campaign C exposure	$104,400,000	$326,250,000	300 × 25% × $4,350,000
Overall credential theft rate	22.1%	24.4%	105 ÷ 430
Email filtering ROI	260,800%	260,900%	($130,500,000 − $50,000) ÷ $50,000
Total risk reduction, full programme	$587,500,000	$587,250,000	90% × $652,500,000
Net benefit, full programme	$587,010,000	$586,760,000	$587,250,000 − $490,000
Credential rate after controls	2.2%	2.4%	24.4% × (1 − 90%)
Breach probability	93.75%	25%	150 is a count, not a probability. The supplied probability is 25%.
30% labelled click-through rate	Click-through	Credential submission rate	Campaign B's click-through rate is 60%
Industry-average columns	15.3%, 18.7%, $285M, 350%	Not used	No source given, and they conflict with the study guide ranges

B. Method changes, where an unjustified assumption was replaced by an explicit one:

Item	Lab figure	Replacement	Reason
Headline annual loss	$652,500,000	$4,350,000	The lab treats 600 compromised accounts as 150 independent breaches a year and labels one quarter's data as annual. Replaced by 4 waves a year × 25% = 1 breach a year.
MFA ROI	724,175%	4,729%	Same formula, applied to the base-case annual loss
Training ROI	391,400%	2,510%	Same formula, applied to the base-case annual loss
Breach cost and control effectiveness	Presented as industry average and expected effectiveness	Scenario assumptions	Not verified. Tested across low, base and high scenarios, with break-even values shown.